NIST Privacy Framework Core	2017 Trust Services Criteria (Inclusive of 2022 updates)	Notes
IDENTIFY-P (ID-P): Develop the organizational understanding to manage privacy risk for individuals arising from data processing.		
Inventory and Mapping (ID.IM-P): Data processing by systems, products, or services is understood and informs the management of privacy risk.		
ID.IM-P1: Systems/products/services that process data are inventoried.	CC2.1 CC3.2 CC6.1	
ID.IM-P2: Owners or operators (e.g., the organization or third parties such as service providers, partners, customers, and developers) and their roles with respect to the systems/products/services and components (e.g., internal or external) that process data are inventoried.	CC2.1 CC3.2 CC6.1	
ID.IM-P3: Categories of individuals (e.g., customers, employees or prospective employees, consumers) whose data are being processed are inventoried.	CC2.1 P6.7	
ID.IM-P4: Data actions of the systems/products/services are inventoried.	CC6.1 P6.7	
ID.IM-P5: The purposes for the data actions are inventoried.	CC6.1 P6.7	
ID.IM-P6: Data elements within the data actions are inventoried.	CC6.1 P6.7	
ID.IM-P7: The data processing environment is identified (e.g., geographic location, internal, cloud, third parties).	CC2.1 CC3.2 CC6.1 P6.2 P6.7	
ID.IM-P8: Data processing is mapped, illustrating the data actions and associated data elements for systems/products/services, including components; roles of the component owners/operators; and interactions of individuals or third parties with the systems/products/services.	CC2.1 CC6.1 P6.2 P6.7	
Business Environment (ID.BE-P): The organization's mission, objectives, stakeholders, and activities are understood and prioritized; this information is used to inform privacy roles, responsibilities, and risk management decisions.		
ID.BE-P1: The organization's role(s) in the data processing ecosystem are identified and communicated.	CC2.2 CC2.3	
ID.BE-P2: Priorities for organizational mission, objectives, and activities are established and communicated.	CC2.2 CC2.3 CC3.1	
ID.BE-P3: Systems/products/services that support organizational priorities are identified and key requirements communicated.	CC2.1 CC3.2 CC6.1	
Risk Assessment (ID.RA-P): The organization understands the privacy risks to individuals and how such privacy risks may create follow-on impacts on organizational operations, including mission, functions, other risk management priorities (e.g. compliance, financial), reputation, workforce, and culture.		
ID.RA-P1: Contextual factors related to the systems/products/services and the data actions are identified (e.g., individuals' demographics and privacy interests or perceptions, data sensitivity, visibility of data processing to individuals and third parties).	CC3.1 CC3.2	
ID.RA-P2: Data analytic inputs and outputs are identified and evaluated for bias.		
ID.RA-P3: Potential problematic data actions and associated problems are identified.	CC3.2	

	ID.RA-P4: Problematic data actions, likelihoods, and impacts are used to determine and prioritize risk.	CC3.2	
	ID.RA-P5: Risk responses are identified, prioritized, and implemented.	CC3.2	
	Data Processing Ecosystem Risk Management (ID.DE-P): The organization's priorities, constraints, risk tolerances, and assumptions are established and used to support risk decisions associated with managing privacy risk and third parties within the data processing ecosystem. The organization has established and implemented the processes to identify, assess, and manage privacy risks within the data processing ecosystem.		
	ID.DE-P1: Data processing ecosystem risk management policies, processes, and procedures are identified, established, assessed, managed, and agreed to by organizational stakeholders.	CC3.1 CC3.2 CC9.1	
	ID.DE-P2: Data processing ecosystem parties (e.g., service providers, customers, partners, product manufacturers, application developers) are identified, prioritized, and assessed using a privacy risk assessment process.	CC9.2 P6.4	
	ID.DE-P3: Contracts with data processing ecosystem parties are used to implement appropriate measures designed to meet the objectives of an organization's privacy program.	CC9.2 P6.1 P6.4	
	ID.DE-P4: Interoperability frameworks or similar multi-party approaches are used to manage data processing ecosystem privacy risks.	CC3.1	
	ID.DE-P5: Data processing ecosystem parties are routinely assessed using audits, test results, or other forms of evaluations to confirm they are meeting their contractual, interoperability framework, or other obligations.	CC9.2 P6.4	
	GOVERN-P (GV-P): Develop and implement the organizational governance structure to enable an ongoing understanding of the organization's risk management priorities that are informed by privacy risk.		
	Governance Policies, Processes, and Procedures (GV.PO-P): The policies, processes, and procedures to manage and monitor the organization's regulatory, legal, risk, environmental, and operational requirements are understood and inform the management of privacy risk.		
	GV.PO-P1: Organizational privacy values and policies (e.g., conditions on data processing such as data uses or retention periods, individuals' prerogatives with respect to data processing) are established and communicated.	CC1.1 CC2.2 CC2.3 CC3.1 CC5.3 P1.1	CC1.1 Establishes Standards of Conduct - This point of focus may be applicable when integrity and ethical values defined in the entity's standards of conduct include privacy values.
	GV.PO-P2: Processes to instill organizational privacy values within system/product/service development and operations are established and in place.	CC8.1 P3.1	
	GV.PO-P3: Roles and responsibilities for the workforce are established with respect to privacy.	CC1.3	
	GV.PO-P4: Privacy roles and responsibilities are coordinated and aligned with third-party stakeholders (e.g., service providers, customers, partners).	CC1.3 CC2.3 CC5.3 CC9.2 P6.4 P6.5	
	GV.PO-P5: Legal, regulatory, and contractual requirements regarding privacy are understood and managed.	CC3.1	
	GV.PO-P6: Governance and risk management policies, processes and procedures address privacy risks.	CC5.3	
	Risk Management Strategy (GV.RM-P): The organization's priorities, constraints, risk tolerances, and assumptions are established and used to support operational risk decisions.		
	GV.RM-P1: Risk management processes are established, managed, and agreed to by organizational stakeholders.	CC3.1 CC3.2 CC5.1 CC5.3 CC9.1	

	GV.RM-P2: Organizational risk tolerance is determined and clearly expressed.	CC3.1	
	GV.RM-P3: The organization's determination of risk tolerance is informed by its role in the data processing ecosystem.	CC3.1	
	Awareness and Training (GV.AT-P): The organization's workforce and third parties engaged in data processing are provided privacy awareness education and are trained to perform their privacy-related duties and responsibilities consistent with related policies, processes, procedures, and agreements and organizational privacy values.		
	GV.AT-P1: The workforce is informed and trained on its roles and responsibilities.	CC1.4 CC2.2	CC1.4 Attracts, Develops, and Retains Individuals and Provides Training to Maintain Technical Competencies - These points of focus may be applicable when mentoring and training include privacy awareness education.
	GV.AT-P2: Senior executives understand their roles and responsibilities.	CC1.1 CC2.2	CC1.1 Sets the Tone at the Top - This point of focus may be applicable when integrity and ethical values cover privacy values.
	GV.AT-P3: Privacy personnel understand their roles and responsibilities.	CC2.2	
	GV.AT-P4: Third parties (e.g., service providers, customers, partners) understand their roles and responsibilities.	CC2.3 CC9.2 P2.1 P6.1 P6.4 P6.5	
	Monitoring and Review (GV.MT-P): The policies, processes, and procedures for ongoing review of the organization's privacy posture are understood and inform the management of privacy risk.		
	GV.MT-P1: Privacy risk is re-evaluated on an ongoing basis and as key factors, including the organization's business environment (e.g., introduction of new technologies), governance (e.g., legal obligations, risk tolerance), data processing, and systems/products/services change.	CC3.4	CC3.4 is applicable when privacy risk is impacted by changes to external environment, business model, leadership, systems and technology, vendor and business partner relationships, and threats and vulnerabilities.
	GV.MT-P2: Privacy values, policies, and training are reviewed and any updates are communicated.	CC5.3	
	GV.MT-P3: Policies, processes, and procedures for assessing compliance with legal requirements and privacy policies are established and in place.	CC3.1 P8.1	
	GV.MT-P4: Policies, processes, and procedures for communicating progress on managing privacy risks are established and in place.	P8.1	
	GV.MT-P5: Policies, processes, and procedures are established and in place to receive, analyze, and respond to problematic data actions disclosed to the organization from internal and external sources (e.g., internal discovery, privacy researchers, professional events).	CC7.3 CC7.4 P8.1 P9.1	
	GV.MT-P6: Policies, processes, and procedures incorporate lessons learned from problematic data actions.	CC7.5	
	GV.MT-P7: Policies, processes, and procedures for receiving, tracking, and responding to complaints, concerns, and questions from individuals about organizational privacy practices are established and in place.	CC2.3 CC4.2 P6.3 P6.6 P8.1	
	CONTROL-P (CT-P): Develop and implement appropriate activities to enable organizations or individuals to manage data with sufficient granularity to manage privacy risks.		
	Data Management Policies, Processes, and Procedures (CT.PO-P): Policies, processes, and procedures are maintained and used to manage data processing (e.g., purpose, scope, roles, responsibilities, management commitment, and coordination among organizational entities) consistent with the organization's risk strategy to protect individuals' privacy.		

	CT.PO-P1: Policies, processes, and procedures for authorizing data processing (e.g., organizational decisions, individual consent), revoking authorizations, and maintaining authorizations are established and in place.	P2.1 P3.2	
	CT.PO-P2: Policies, processes, and procedures for enabling data review, transfer, sharing or disclosure, alteration, and deletion are established and in place (e.g., to maintain data quality, manage data retention).	P4.2 P4.3 P5.1 P5.2 P6.1 P7.1	
	CT.PO-P3: Policies, processes, and procedures for enabling individuals' data processing preferences and requests are established and in place.	P5.1 P5.2 P6.7	
	CT.PO-P4: An information life cycle to manage data is aligned and implemented with the system development life cycle to manage systems.	CC8.1	
	Data Processing Management (CT.DM-P): Data are managed consistent with the organization's risk strategy to protect individuals' privacy, increase manageability, and enable the implementation of privacy principles (e.g., individual participation, data quality, data minimization).		
	CT.DM-P1: Data elements can be accessed for review.	P5.1	
	CT.DM-P2: Data elements can be accessed for transmission or disclosure.	P6.7	
	CT.DM-P3: Data elements can be accessed for alteration.	P5.2	
	CT.DM-P4: Data elements can be accessed for deletion.	P4.3	
	CT.DM-P5: Data are destroyed according to policy.	C1.2 P4.3	
	CT.DM-P6: Data are transmitted using standardized formats.		
	CT.DM-P7: Mechanisms for transmitting processing permissions and related data values with data elements are established and in place.		
	CT.DM-P8: Audit/log records are determined, documented, implemented, and reviewed in accordance with policy and incorporating the principle of data minimization.	CC7.2	CC7.2 Implements Detection Policies, Procedures, and Tools - This point of focus is applicable when policies, procedures and governance process for detection and logging tools include data minimization requirements.
	CT.DM-P9: Technical measures implemented to manage data processing are tested and assessed.		
	CT.DM-P10: Stakeholder privacy preferences are included in algorithmic design objectives and outputs are evaluated against these preferences.		
	Disassociated Processing (CT.DP-P): Data processing solutions increase disassociability consistent with related policies, processes, procedures, and agreements and the organization's risk strategy to protect individuals' privacy.		
	CT.DP-P1: Data are processed in an unobservable or unlinkable manner (e.g., data actions take place on local devices, privacy-preserving cryptography).		
	CT.DP-P2: Data are processed to limit the identification of individuals (e.g., de-identification privacy techniques, tokenization).		
	CT.DP-P3: Data are processed to restrict the formulation of inferences about individuals' behavior or activities (e.g., data processing is decentralized, distributed architectures).		
	CT.DP-P4: System or device configurations permit selective collection or disclosure of data elements.	P3.1 P4.1	
	CT.DP-P5: Attribute references are substituted for attribute values.		
	COMMUNICATE-P (CM-P): Develop and implement appropriate activities to enable organizations and individuals to have a reliable understanding about how data are processed and associated privacy risks.		

	Communication Policies, Processes, and Procedures (CM.PO-P): Policies, processes, and procedures are maintained and used to increase transparency of the organization's data processing practices (e.g., purpose, scope, roles, responsibilities, management commitment, and coordination among organizational entities) and associated privacy risks.		
	CM.PO-P1: Transparency policies, processes, and procedures for communicating data processing purposes, practices, and associated privacy risks are established and in place.	CC2.2 CC2.3 P1.1	
	CM.PO-P2: Roles and responsibilities (e.g., public relations) for communicating data processing purposes, practices, and associated privacy risks are established.		
	Data Processing Awareness (CM.AW-P): Individuals and organizations have reliable knowledge about data processing practices and associated privacy risks, and effective mechanisms are used and maintained to increase predictability consistent with the organization's risk strategy to protect individuals' privacy.		
	CM.AW-P1: Mechanisms (e.g., notices, internal or public reports) for communicating data processing purposes, practices, associated privacy risks, and options for enabling individuals' data processing preferences and requests are established and in place.	CC2.3 P1.1 P2.1 P3.2 P8.1	
	CM.AW-P2: Mechanisms for obtaining feedback from individuals (e.g., surveys or focus groups) about data processing and associated privacy risks are established and in place.	CC2.3	
	CM.AW-P3: System/product/service design enables data processing visibility.		
	CM.AW-P4: Records of data disclosures and sharing are maintained and can be accessed for review or transmission/disclosure.	P6.2 P6.3	
	CM.AW-P5: Data corrections or deletions can be communicated to individuals or organizations (e.g., data sources) in the data processing ecosystem.	P5.2	
	CM.AW-P6: Data provenance and lineage are maintained and can be accessed for review or transmission/disclosure.		
	CM.AW-P7: Impacted individuals and organizations are notified about a privacy breach or event.	CC7.4 CC7.5 P6.6	
	CM.AW-P8: Individuals are provided with mitigation mechanisms (e.g., credit monitoring, consent withdrawal, data alteration or deletion) to address impacts of problematic data actions.		
	PROTECT-P (PR-P): Develop and implement appropriate data processing safeguards.		
	Data Protection Policies, Processes, and Procedures (PR.PO-P): Security and privacy policies (which address purpose, scope, roles, responsibilities, management commitment, and coordination among organizational entities), processes, and procedures are maintained and used to manage the protection of data.		
	PR.PO-P1: A baseline configuration of information technology is created and maintained incorporating security principles (e.g., concept of least functionality).	CC7.1 CC8.1	
	PR.PO-P2: Configuration change control processes are established and in place.	CC8.1	
	PR.PO-P3: Backups of information are conducted, maintained, and tested.	A1.2 A1.3	
	PR.PO-P4: Policy and regulations regarding the physical operating environment for organizational assets are met.	CC3.4 A1.2	
	PR.PO-P5: Protection processes are improved.	CC4.2 CC5.3	
	PR.PO-P6: Effectiveness of protection technologies is shared.	CC2.3 CC4.2 CC7.2	

PR.PO-P7: Response plans (Incident Response and Business Continuity) and recovery plans (Incident Recovery and Disaster Recovery) are established, in place, and managed.	CC7.3 CC7.4 CC9.1	
PR.PO-P8: Response and recovery plans are tested.	CC7.3 A1.3	
PR.PO-P9: Privacy procedures are included in human resources practices (e.g., deprovisioning, personnel screening).	CC6.3 CC6.4	
PR.PO-P10: A vulnerability management plan is developed and implemented.	CC3.2 CC4.1 CC7.1 CC7.4	
Identity Management, Authentication, and Access Control (PR.AC-P): Access to data and devices is limited to authorized individuals, processes, and devices, and is managed consistent with the assessed risk of unauthorized access.		
PR.AC-P1: Identities and credentials are issued, managed, verified, revoked, and audited for authorized individuals, processes, and devices.	CC5.2 CC6.1 CC6.2 CC6.3	
PR.AC-P2: Physical access to data and devices is managed.	CC6.4	
PR.AC-P3: Remote access is managed.	CC6.1 CC6.6	
PR.AC-P4: Access permissions and authorizations are managed, incorporating the principles of least privilege and separation of duties.	CC6.1 CC6.3	
PR.AC-P5: Network integrity is protected (e.g., network segregation, network segmentation).	CC6.1	
PR.AC-P6: Individuals and devices are proofed and bound to credentials, and authenticated commensurate with the risk of the transaction (e.g., individuals' security and privacy risks and other organizational risks).	CC6.1	
Data Security (PR.DS-P): Data are managed consistent with the organization's risk strategy to protect individuals' privacy and maintain data confidentiality, integrity, and availability.		
PR.DS-P1: Data-at-rest are protected.	CC6.1	
PR.DS-P2: Data-in-transit are protected.	CC6.1	
PR.DS-P3: Systems/products/services and associated data are formally managed throughout removal, transfers, and disposition.	CC6.1 CC6.5	
PR.DS-P4: Adequate capacity to ensure availability is maintained.	A1.1	
PR.DS-P5: Protections against data leaks are implemented.	CC6.1 CC6.6 CC7.2	
PR.DS-P6: Integrity checking mechanisms are used to verify software, firmware, and information integrity.	CC6.8 CC7.1	
PR.DS-P7: The development and testing environment(s) are separate from the production environment.		
PR.DS-P8: Integrity checking mechanisms are used to verify hardware integrity.	CC7.1	
Maintenance (PR.MA-P): System maintenance and repairs are performed consistent with policies, processes, and procedures.		
PR.MA-P1: Maintenance and repair of organizational assets are performed and logged, with approved and controlled tools.	CC8.1	
PR.MA-P2: Remote maintenance of organizational assets is approved, logged, and performed in a manner that prevents unauthorized access.	CC8.1	

	Protective Technology (PR.PT-P): Technical security solutions are managed to ensure the security and resilience of systems/products/services and associated data, consistent with related policies, processes, procedures, and agreements.		
	PR.PT-P1: Removable media is protected and its use restricted according to policy.	CC6.7	
	PR.PT-P2: The principle of least functionality is incorporated by configuring systems to provide only essential capabilities.	CC7.1	CC7.1 Uses Defined Configuration Standards - This point of focus may be applicable when it covers principle of least functionality.
	PR.PT-P3: Communications and control networks are protected.	CC6.7	
	PR.PT-P4: Mechanisms (e.g., failsafe, load balancing, hot swap) are implemented to achieve resilience requirements in normal and adverse situations.	A1.2	